

Digitale Gesundheitsplattformen und APIs

Architekturansätze für skalierbare e-Health Vernetzung am Beispiel der Telematikinfrastuktur

Dr. Fabian Franzelin

2026-09-24

Willkommen zur Vorlesung

Schön, dass ich heute bei Ihnen sein darf.

Was ich heute mitbringe:

- Mich, einen **Softwarearchitekten**
- Einen **Leitfall** für die **Telematikinfrastruktur 2.0**
- Vier **Architekturprinzipien**
- Einen **Architekturansatz** zur **Skalierbarkeit** von e-Health Plattformen

Was Sie mitbringen:

- Sich, motivierte **Studierende**
- Info 1/2: **UML-Sequenzdiagramme**
- Medizininformatik: **Prozesse**
- **Neugier** auf: Cloud, Container, Zero Trust

Eine Nachricht, fünf Perspektiven

"Ein solches System konnte bisher noch nie gehackt werden." Karl Lauterbach, 2024, Einführung der ePA

- **Als CCC:** Wie hacke ich das System? ¹
- **Als Patient:** Sind meine Daten sicher?
- **Als gematik:** Wie reagiert man auf so einen Hack? → TI 2.0
- **Als angehende Informatiker:** Wie baut man so etwas *richtig*?
- **Als Vortragender heute:** Zeigen wir das an einem Alltagsfall — der elektronischen Arbeitsunfähigkeitsbescheinigung (eAU).

¹Martin Tschirsich, Bianca Kastl, "Konnte bisher noch nie gehackt werden: Die elektronische Patientenakte kommt — jetzt für alle!", 38C3, Chaos Computer Club, 27.12.2024. [Link](#)

Die elektronische Arbeitsunfähigkeitsbescheinigung

Was ist die eAU? Ein verteilter Prozess

- Praxissoftware erfasst und signiert die Bescheinigung.
- Die Krankenkasse erhält die für sie bestimmten Daten.²
- Der Arbeitgeber ruft die für ihn erforderlichen Daten ab.

Rollen? Prozesse? → Sequenzdiagramme

Phase 1: Datenerhebung & Kassenmeldung

- Identität vor Zugriff (Arzt)
- Heterogene Primärsysteme (PVS, VZD, KIM)
- Kommunikation über offene Netze

Phase 2: Krankmeldung und eAU-Abruf

- Abruf an Person, Zeitraum und Zweck gebunden
- Asynchrone Übermittlung

Prinzip 1: Zero Trust

Zero Trust beschreibt ein aus dem "Assume Breach"-Ansatz entwickeltes Architekturdesign-Paradigma, welches im Kern auf dem Prinzip der minimalen Rechte aller Entitäten in der Gesamtinfrastruktur basiert.³

Das beinhaltet:

1. Jeder einzelne Zugriff muss authentifiziert werden
2. Jeder einzelne Zugriff muss verschlüsselt werden
3. Minimale Datenweitergabe → *need-to-know* Prinzip
4. Die Berechtigungen sind kontextbezogen

Prinzip 2: HW-Abstraktion & Cloud

Die Telematikinfrastruktur der Zukunft soll [...] den Konnektor durch zentrale, cloudbasierte Zugangsdienste (TI-Gateway) ablösen und so kurze Update- und Release-Zyklen ermöglichen.⁴

Schauen wir uns die eAU wieder an...

Im Mittel bei einem Zugriff pro eAU auf einen Arbeitstag (8h)⁵

$\frac{496 \text{ Mio. Fälle seit 01.08.2021}}{5.1 \text{ Jahre}} \approx 97 \text{ Mio. Fälle/Jahr} \approx 265 \text{ Tsd. Fälle/Tag} \approx 9 \text{ Fälle/Sekunde}$

Schranken für die Auslegungslast

- eAU: ca. 9 Zugriffe/Sekunde⁶
- E-Rezept: ca. 152 Verordnungen/Sekunde⁷
- elektronische Patientenakte: ca. 235 Zugriffe/Sekunde⁸

Kennzahl	Wert [Zugriffe/s]	Herleitung
Durchschnittlicher Wert pro Tag	ca. 9	Mittelwert / Minute

Zusammenfassung

1. **Digitale Gesundheitsplattform:** Viele Rollen, eine Fachaufgabe
2. **APIs & offene Standards** (FHIR, OAuth/OIDC): Vernetzung wird dienstorientiert
3. **Skalierbarkeit:** Von 9 Zugriffen/s (eAU-Mittel) bis ~2.350/s (Peak, ePA-Klasse) — elastisch durch Cloud.
4. **Telematikinfrastruktur 2.0:** Zero Trust statt Netz-Perimeter — Vertrauen an Identität und Kontext gebunden
"Ein solches System konnte bisher noch nie gehackt werden." Zukünftiges Ich

TI vs. Internet — ein Vergleich

Dimension	Internet	TI 1.x
Grundannahme	Offenes Netz, "assume hostile"	Geschlossenes Netz,
Zugang	Jeder mit IP-Adresse	Nur über zugelassene
Adressierung	DNS, IP, URL	KIM-Adressen, VPN-
Identität	Optional (TLS-Zertifikat, Login je Dienst)	An Karte/Konnektor
Sicherheit	Ende-zu-Ende auf Anwendungsebene (TLS, OAuth)	Netzwerksegmentierung
Governance	IETF/W3C, dezentral, konsensbasiert	gematik, staatlich re
Standards	HTTP, TLS, JSON, OAuth	Eigene TI-Fachdienst
Skalierung	Horizontal, global, CDN	Begrenzt durch Konn
Ausfallverhalten	Best effort, redundante Pfade	Einzelner Konnektor
Datenmodell	Anwendungsspezifisch	FHIR/CDA + Spezif

Frage 1

Wie sicher sind meine Gesundheitsdaten in der Telematikinfrastruktur?

Die TI schützt Daten durch starke Identitäten, Verschlüsselung und rollenbasierte Zugriffsrechte. Absolute Sicherheit gibt es nicht: Deshalb müssen Zugriffe bei jeder Anfrage geprüft, protokolliert und auf das erforderliche Minimum begrenzt werden. Genau diesen Wandel von Netzvertrauen zu **Zero Trust** verfolgt die TI 2.0.

Frage 2

Warum reicht ein geschlossenes Netz nicht aus, um Gesundheitsdaten zu schützen?

Ein geschlossenes Netz schützt vor manchen Angriffen von außen, aber nicht automatisch vor kompromittierter Hardware, gestohlenen Karten oder zu weit gefassten Berechtigungen. Sicherheit muss deshalb an Identität, Rolle, Zweck und Kontext eines einzelnen Zugriffs gebunden sein, nicht nur an den Ort im Netzwerk.